SANITIZED PORTFOLIO SAMPLE

AWS SECURITY POSTURE REVIEW

Management Summary

Executive view of selected foundational AWS security controls, confirmed findings, and recommended next steps.

PREPARED FOR

ACME CORPORATION

AWS Account: 123456789012
Assessment: ASC-SAMPLE-2026-001
Prepared: October 12, 2026

Example Security Provider
Point-in-time, read-only AWS security posture assessment

MANAGEMENT SUMMARY

AWS Security Posture Review

Executive view of selected foundational AWS security controls, confirmed findings, and recommended next steps.

ACME CORPORATION

AWS ACCOUNT	ASSESSMENT	PREPARED
123456789012	ASC-SAMPLE-2026-001	**October 12, 2026**

CONTROLS EVALUATED	PASSED	CONFIRMED FINDINGS
9	6	3

Executive takeaway

6 of 9 evaluated controls passed at the time of review. 3 confirmed findings require remediation; the highest confirmed severity is HIGH.

PRIORITY OVERVIEW

Confirmed Findings

1. HIGH - CloudTrail multi-region trail is not enabled

Detection | Estimated effort: medium

2. HIGH - IAM account password policy is not configured

Identity and access management | Estimated effort: low

3. HIGH - S3 account-level Block Public Access is not configured

Data protection | Estimated effort: low

MANAGEMENT ACTION 1 OF 3

HIGH

CloudTrail multi-region trail is not enabled

Detection | Estimated effort: medium

What we found

No multi-region CloudTrail trail was detected in the connected account.

Why it matters

Without a multi-Region trail, API activity in Regions outside the trail's coverage may be missing from the organization's ongoing audit record. That does not imply suspicious activity is occurring, but it can create a visibility gap that slows detection, investigation, and incident reconstruction if unauthorized or accidental changes occur in an uncovered Region.

Recommended next step

Create a new multi-Region CloudTrail trail or convert an appropriate existing trail to multi-Region coverage. Protect the destination logs according to organizational logging and retention requirements.

Success looks like

At least one CloudTrail trail is configured as a multi-Region trail.

OFFICIAL AWS GUIDANCE

Security best practices in AWS CloudTrail

MANAGEMENT ACTION 2 OF 3

HIGH

IAM account password policy is not configured

Identity and access management | Estimated effort: low

What we found

No IAM account password policy was found for the connected account.

Why it matters

A weak or absent IAM password policy can allow shorter, simpler, or repeatedly reused passwords. Those choices are generally more susceptible to password guessing, password spraying, credential-reuse attacks, or recovery if the same credential is exposed elsewhere. This finding does not mean an account has been compromised; it means an important layer of resistance to password-based attacks is below the assessed baseline. MFA remains an important additional safeguard for human identities.

Recommended next step

Review the reported policy gaps and configure the IAM account password policy to meet the assessed baseline: minimum length 14, uppercase, lowercase, number and symbol requirements, password reuse prevention, and a maximum password age. Also require MFA for human identities.

Success looks like

IAM Account settings show a minimum password length of 14 or greater, uppercase, lowercase, number, and symbol requirements enabled, password reuse prevention configured, and a maximum password age configured.

OFFICIAL AWS GUIDANCE

Set an account password policy for IAM users

MANAGEMENT ACTION 3 OF 3

HIGH

S3 account-level Block Public Access is not configured

Data protection | Estimated effort: low

What we found

No account-level S3 Public Access Block configuration was found for the connected account.

Why it matters

Missing account-level Block Public Access does not mean the account currently has a public bucket. It means an important preventive guardrail is absent, so a later bucket policy, ACL, or access-point configuration mistake has a greater chance of making S3 data publicly reachable. Depending on the data involved, that could lead to unintended disclosure of customer, operational, or proprietary information.

Recommended next step

Review workloads that intentionally require public S3 access, then enable the four account-level Block Public Access settings where compatible: BlockPublicAcls, IgnorePublicAcls, BlockPublicPolicy, and RestrictPublicBuckets.

Success looks like

All four effective account-level S3 Block Public Access settings are enabled: BlockPublicAcls, IgnorePublicAcls, BlockPublicPolicy, and RestrictPublicBuckets.

OFFICIAL AWS GUIDANCE

Configuring block public access settings for your account

ASSESSMENT CONTEXT

What the Review Confirmed

Evidence matters

The assessment documents both remediation priorities and controls already confirmed in the desired state. Passed controls remain part of the customer deliverable rather than disappearing from view.

SECURITY PILLAR AREAS

Identity and access management

5 of 6 evaluated checks passed; 1 item needs attention.

Detection

0 of 1 evaluated checks passed; 1 item needs attention.

Infrastructure protection

1 of 1 evaluated checks passed; all applicable checks passed.

Data protection

0 of 1 evaluated checks passed; 1 item needs attention.

CONTROLS CONFIRMED IN GOOD STATE

- Root user MFA is enabled
- Root account access keys are not present
- All IAM users have MFA enabled
- No IAM access keys unused for 90 days or more were found
- No old IAM access keys were found
- No security groups expose SSH or RDP to the internet

BOUNDED ASSESSMENT

Scope & Next Step

ASSESSMENT TYPE

Point-in-time

ACCESS MODEL

Read-only

Assessment scope

This assessment evaluates selected foundational AWS security controls informed by AWS security guidance and the Security Pillar of the AWS Well-Architected Framework. Account-global controls were evaluated at the account level. The SSH/RDP security-group control covered all AWS Regions enabled for the account at assessment time. This is NOT a complete AWS Well-Architected Review.

Access model

The review used temporary read-only access through a customer-deployed AWS role and did not modify AWS resources.

Assessment provider & contact

Assessment provider: Example Security Provider. Contact details are intentionally omitted from this sanitized portfolio sample.

Included follow-up verification

One follow-up point-in-time verification of remediated findings is included at no additional cost.

Recommended disposition

Complete the confirmed remediation actions, validate the AWS-side success criteria, then request a follow-up point-in-time verification of the affected controls.